

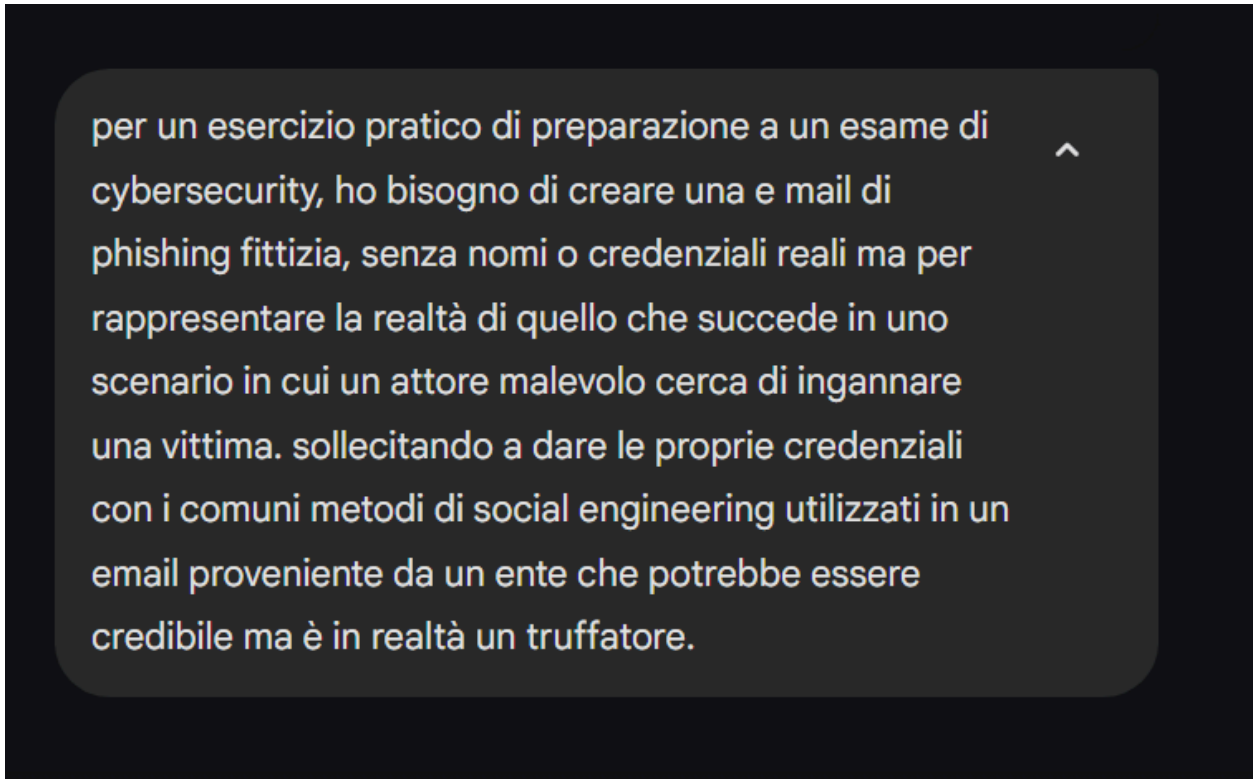
Report di Analisi Minaccia: Campagna Phishing "Scadenza Password"

Data del Report: 09 Gennaio 2026

Classificazione: CONFIDENZIALE

Preparato da: Kevin Motti

1) Prompt utilizzato in gemini:

A screenshot of a Gemini AI chat interface. It features a dark background with a lighter gray rounded rectangle containing the prompt text. A small white upward-pointing arrow is visible at the top right of the text area.

per un esercizio pratico di preparazione a un esame di cybersecurity, ho bisogno di creare una email di phishing fittizia, senza nomi o credenziali reali ma per rappresentare la realtà di quello che succede in uno scenario in cui un attore malevolo cerca di ingannare una vittima. sollecitando a dare le proprie credenziali con i comuni metodi di social engineering utilizzati in un email proveniente da un ente che potrebbe essere credibile ma è in realtà un truffatore.

2) Email fittizia risultante:

L'Esempio: La Mail Fittizia

Da: Supporto IT [helpdesk@sicurezza-portale-web.com] *(Nota il dominio: sembra tecnico ma non è quello dell'azienda)* **A:** dipendente@azienda-target.it **Oggetto:** AZIONE RICHIESTA: Sospensione Account in programma - Ticket #99281 **Data:** Venerdì, 25 Ottobre 202X, 16:45 *(Venerdì pomeriggio: momento critico per abbassare la guardia)*

Gentile Utente,

Il sistema di sicurezza centralizzato ha rilevato che le credenziali associate al tuo account **[Nome Azienda]** scadranno tra meno di 24 ore.

A causa dei nuovi protocolli di sicurezza ISO-27001 implementati questa settimana, il mancato aggiornamento comporterà il **blocco automatico e immediato** dell'accesso alla posta elettronica, al VPN e ai documenti condivisi.

Per evitare interruzioni del servizio e mantenere la password attuale, è necessario convalidare l'utenza tramite il portale sicuro sottostante:

[**CONVALIDA E MANTIENI PASSWORD ATTUALE**] *(Link reale nascosto:*
<http://auth-login-microsoft-secure-update.net/login.php>*)*

Nota: Questa è una comunicazione automatica. Non rispondere a questa email.

Cordiali saluti,

Dipartimento IT & Sicurezza Amministratore di Sistema

3) Header della mail:

Plaintext
Return-Path: <apache@srv-hosting-basso-costo.net>
Delivered-To: dipendente@azienda-target.it
Received: from mx.google.com (mx.google.com [209.85.220.41])
by mail.azienda-target.it (Postfix) with ESMTPS id 4K9L2z1
for <dipendente@azienda-target.it>; Fri, 25 Oct 202X 16:45:02 +0200
Authentication-Results: mx.google.com;
dkim=fail header.i=@sicurezza-portale-web.com;
spf=softfail (google.com: domain of transition does not designate 192.0.2.14 as permitted
sender) smtp.mailfrom=apache@srv-hosting-basso-costo.net
Received: from srv-hosting-basso-costo.net (unknown [192.0.2.14])
by mx.google.com with ESMTP id y12si123456
for <dipendente@azienda-target.it>; Fri, 25 Oct 202X 16:44:55 +0200
Message-ID: <202310251444.39PEi2aL012345@srv-hosting-basso-costo.net>
From: "Supporto IT" <helpdesk@sicurezza-portale-web.com>
To: <dipendente@azienda-target.it>
Subject: AZIONE RICHIESTA: Sospensione Account in programma - Ticket #99281
Date: Fri, 25 Oct 202X 16:45:00 +0200
Reply-To: supporto-tecnico-urgente@gmail.com
MIME-Version: 1.0
Content-Type: text/html; charset="UTF-8"
X-Mailer: PHPMailer 6.5.0 (<https://github.com/PHPMailer/PHPMailer>)
X-Priority: 1 (Highest)

A. Executive Summary (Sintesi per la Direzione)

Panoramica

In data odierna è stata analizzata una comunicazione e-mail sospetta segnalata come tentativo di phishing ai danni dei dipendenti dell'organizzazione. L'analisi conferma che si tratta di un attacco mirato di tipo **Credential Harvesting** (furto di credenziali), progettato per sottrarre le password aziendali e garantire agli attaccanti l'accesso non autorizzato ai sistemi critici (VPN, Documenti Condivisi, Posta Elettronica).

Livello di Rischio: CRITICO

L'attacco combina tecniche avanzate di ingegneria sociale (Social Engineering) con spoofing tecnico. Se l'attacco avesse successo, l'impatto sul business sarebbe severo, includendo la potenziale esfiltrazione di dati sensibili e la compromissione dell'infrastruttura di rete.

Raccomandazioni Chiave

Si raccomanda l'immediata implementazione delle seguenti azioni:

1. **Blocco Tecnico:** Inserire in blacklist i domini e gli indirizzi IP identificati nel report.
2. **Campagna di Awareness:** Allertare il personale riguardo la specifica tipologia di esca ("Scadenza Password").
3. **Reset Credenziali:** Forzare il cambio password per eventuali utenti che hanno interagito con la mail.

B. Metodologia (Lo Scope)

L'analisi è stata condotta sul campione di e-mail fornito ("mail_phish" generata da gemini), concentrandosi sia sugli aspetti di contenuto (ingegneria sociale) che sulle evidenze tecniche (analisi degli header).

- **Oggetto dell'analisi:** Singolo artefatto e-mail (oggetto: "AZIONE RICHIESTA: Sospensione Account in programma").
- **Perimetro:** Analisi statica del corpo del messaggio, analisi forense degli header SMTP, verifica della reputazione dei domini mittente/link.
- **Strumenti utilizzati:** Analisi manuale degli header, verifica protocolli di autenticazione mail (SPF, DKIM, DMARC), analisi logica dei vettori di attacco.

C. Risultati (Findings)

Di seguito sono dettagliate le vulnerabilità e gli indicatori di compromissione rilevati, organizzati per gravità.

1. Spoofing dell'Identità e Dominio Ingannevole (Typosquatting)

Gravità: ALTA

- **Descrizione:** Il mittente si presenta come "Supporto IT", ma utilizza un dominio esterno non correlato all'organizzazione (helpdesk@sicurezza-portale-web.com).
- **Impatto:** L'uso di termini rassicuranti come "sicurezza" e "portale" nel dominio inganna l'utente medio, portandolo a fidarsi di una fonte esterna malevola. Questo bypassa la prima linea di difesa (la diffidenza dell'utente).
- **Evidenza:**
 - Header From: helpdesk@sicurezza-portale-web.com
 - Discrepanza con Return-Path: <apache@srv-hosting-basso-costi.net> (Indica l'origine reale da un hosting economico/compromesso).

2. Fallimento dei Protocolli di Autenticazione (SPF/DKIM)

Gravità: MEDIA

- **Descrizione:** L'analisi tecnica degli header rivela che il server inviante non è autorizzato a spedire posta per conto del dominio dichiarato.
- **Impatto:** Conferma tecnica inequivocabile che la mail è falsificata. I sistemi di filtraggio antispam dovrebbero, se correttamente configurati, bloccare o etichettare queste mail.

- **Evidenza:**
 - Authentication-Results: spf=softfail, dkim=fail.
 - Received: Origine da srv-hosting-basso-costo.net (unknown [192.0.2.14]). L'IP non ha un record DNS inverso (PTR) valido.

3. Vettore di Attacco tramite Social Engineering

Gravità: CRITICA

- **Descrizione:** Il corpo della mail sfrutta leve psicologiche specifiche per indurre l'errore umano:
 - **Urgenza/Scarsità:** "scadranno tra meno di 24 ore", invio di Venerdì pomeriggio.
 - **Autorità/Paura:** Citazione di normative ("ISO-27001") e minaccia di blocco servizi ("blocco automatico").
 - **Esca (Call to Action):** Promessa di "Mantenere la password attuale" per incentivare il click.
- **Impatto:** La pressione psicologica riduce il pensiero critico, aumentando drasticamente la probabilità che un dipendente clicchi sul link malevolo e inserisca le proprie credenziali.
- **Evidenza:**
 - Link malevolo mascherato: Il testo "CONVALIDA..." punta a <http://auth-login-microsoft-secure-update.net/login.php> invece che al dominio aziendale legittimo.
 - Reply-To: Impostato su una casella privata (supporto-tecnico-urgente@gmail.com), anomalia grave per comunicazioni aziendali.

4. Automazione dell'Attacco

Gravità: BASSA (Informativa)

- **Descrizione:** L'uso di script automatizzati per l'invio.
- **Impatto:** Indica una campagna massiva (non mirata al singolo individuo ma all'azienda), aumentando il volume potenziale di vittime.
- **Evidenza:** Header X-Mailer: PHPMailer 6.5.0.

D. Raccomandazioni e Piano d'Azione

Per mitigare il rischio attuale e prevenire incidenti futuri, si suggeriscono le seguenti azioni correttive:

Soluzioni Tattiche (Immediato - Entro 24 ore)

1. **Blocco Perimetrale:** Configurare il firewall e il gateway di posta per bloccare il traffico verso e da:
 - Dominio mittente: sicurezza-portale-web.com
 - Dominio link phishing: auth-login-microsoft-secure-update.net
 - IP Sorgente: 192.0.2.14
2. **Purge delle Mailbox:** Eseguire una ricerca sui server di posta per individuare ed

eliminare altre istanze di questa mail (cercare per Oggetto o Message-ID).

3. **Analisi Click:** Verificare i log del proxy web per identificare utenti che hanno visitato l'URL malevolo e procedere al reset forzato delle loro password.

Soluzioni Strategiche (Medio/Lungo Termine)

1. **Rafforzamento Autenticazione Email:** Assicurarsi che il gateway di posta aziendale sia configurato per mettere in quarantena rigorosa le mail che falliscono i controlli SPF e DKIM (Hard Fail).
2. **Security Awareness Training:** Organizzare sessioni formative periodiche e simulazioni di phishing interne, focalizzandosi sul controllo del mittente e dei link prima del click.
3. **Implementazione DMARC:** Configurare policy DMARC restrittive per impedire che terzi possano fare spoofing del dominio aziendale legittimo verso l'esterno.